

Unlokt — GDPR & procurement pack

For: the Gender Capital Lab™ Sprint platform (`ifc-sprint-platform.vercel.app`). Prepared 2026-06-13.

This folder holds the documents a financial-services client's privacy and procurement teams will ask for before they let the platform touch their data.

Not legal advice — drafts for review. These are professional starting points written from the platform's actual architecture. A DPA is a binding contract and a DPIA is a regulated assessment. **Have a privacy lawyer or a DPO review everything in this folder before you sign or send it.** Where a fact could not be confirmed on an official source, it is marked **△ CONFIRM** — close those before anything is signed.

What's here

File	What it is	Audience
01_data-flow-and-residency.md	The honest map: what personal data the platform holds, and exactly where it goes (EU vs US).	Internal + client privacy team
02_subprocessor-list.md	The three subprocessors (Anthropic, Vercel, Turso), their role, location, and DPA/transfer posture.	Client procurement
03_DPA-template.md	Verwerkersovereenkomst (Data Processing Agreement) draft — Unlokt as processor, the client as controller, with annexes.	Lawyers, both sides
04_retention-and-deletion.md	How long data is kept and how it is erased (the platform has a working delete + backup capability).	Client privacy team
05_security-measures-TOMs.md	Technical & organisational measures — honest, including current gaps.	Client security team
06_DPIA-input.md	Input for the client's Data Protection Impact Assessment (they run it; we supply the processing facts and risks).	Client DPO
07_security-questionnaire-prefill.md	Pre-filled answers to the standard vendor security questionnaire.	Client procurement
08_privacy-notices-NL.md	Ready-to-use Dutch consent & notice text for the crew intake and the test panel.	Goes into the product
09_open-items-and-decisions.md	The risk register: what must be confirmed, obtained, or decided before the first real client sprint.	Founders

The one-paragraph version (for a first procurement conversation)

Data at rest lives in the EU (Turso, Ireland). Application compute runs in the EU (Vercel, Frankfurt). The only data leaving the EU is what is sent to the Claude AI for analysis — processed in the US by Anthropic under Standard Contractual Clauses, **never used to train models**, and auto-deleted within 30 days. Personal data is minimised, access is controlled, and there is a working data-erasure process. Full DPA, subprocessor list and security measures available on request.

Read `09_open-items-and-decisions.md` before you say any of that out loud — a few claims still need a manual confirmation.